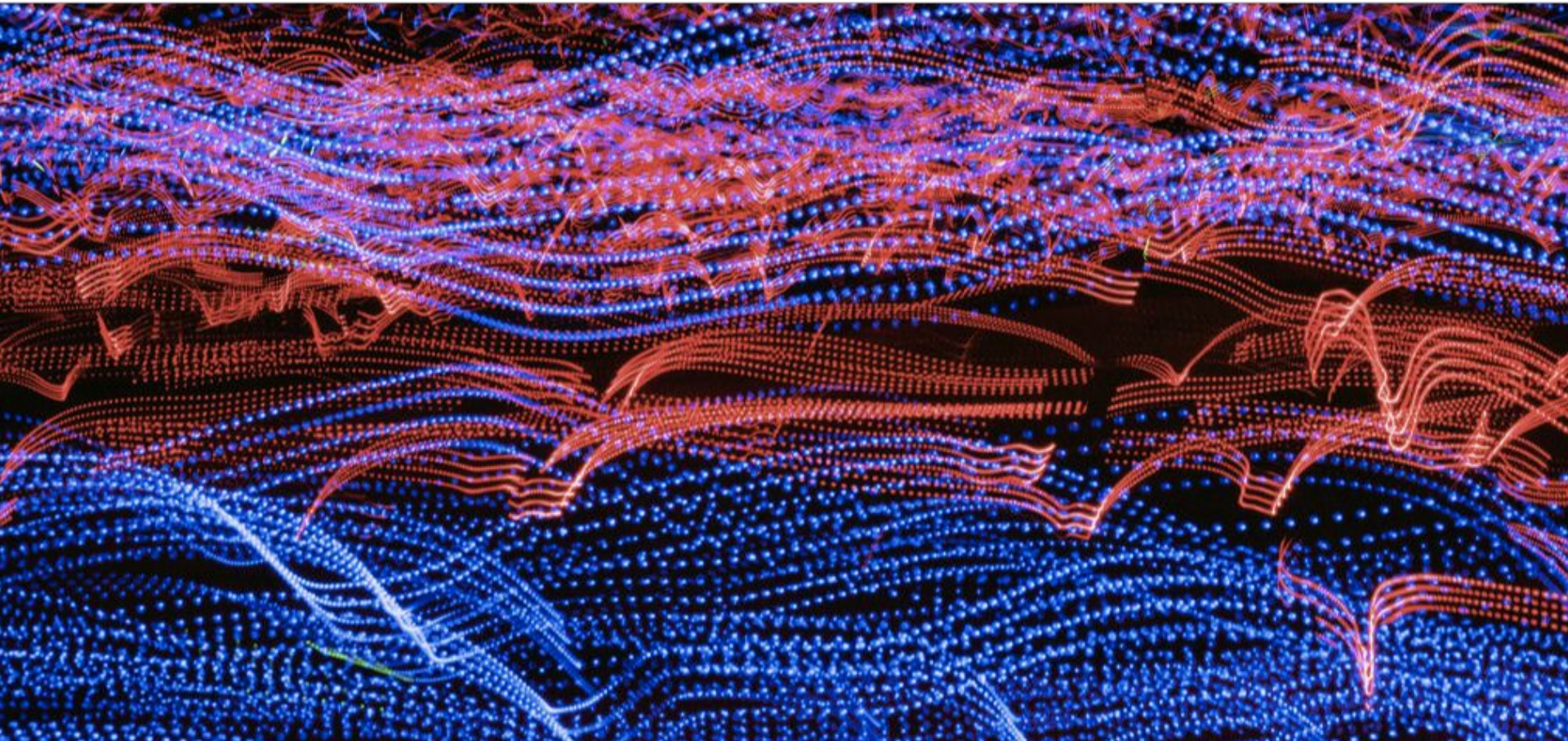


7. Critical Systems, Security & Privacy

Kristof Van Laerhoven - Ubiquitous Computing

kvl@eti.uni-siegen.de



1. History and definition of Ubiquitous Computing
2. Designing Experiments for UbiComp
3. Wearable Computing to Nomadic Technology
4. Wireless Sensor-Actuator Networks to Smart Dust
5. Physical Interaction to Tangible Interfaces
6. Context Awareness to Detecting Activity
- 7. Critical Systems Design to Security & Privacy**

Outline

- Examples
- Privacy
 - Defining Privacy
 - Privacy and Technology
 - Privacy history
 - Why Privacy? Example AOLSearch
 - Anonymity and Pseudonymity
- Security in communication
 - Basic concepts in cryptography
 - Mono- & Polyalphabetic ciphers
 - Stream cipher and block cipher
 - Public key cryptography, Hash, Signatures
- **Critical Systems: Some case studies**

Case Studies

- Systems are rarely perfect from their first version
- For many systems, bugs and failures just lead to *patches* and *version updates*
- For safety-critical systems, the impact is much much higher
- Important in that case:
Proper analysis through incident reports, which are then used as “teachable moments” or:
case studies

FACILITY	DATE	REPORT ID
EAST VALLEY NUCLEAR PLANT	12/10/2021	9603120071
EVENT DESCRIPTION		
ROUGHLY 18 HOURS PRIOR TO THE INCIDENT, AN AMAZON PACKAGE CONTAINING FIREWORKS WAS MISTAKENLY DELIVERED TO THE REACTOR CONTROL ROOM AND LEFT UNDER THE CONSOLE. THE NEXT DAY, AT APPROXIMATELY 14:00, TECHNICIAN A ARRIVED AT THE FACILITY WITH A BAG CONTAINING FOUR JUGGLING PINS. AT 14:20, TECHNICIAN A ENTERED THE CONTROL ROOM AND JOINED TECHNICIAN B AT THE CONSOLE. AT 14:28, TECHNICIAN C EXITED THE ELEVATOR AND APPROACHED THE CONTROL ROOM HOLDING A BIRTHDAY CAKE INTENDED FOR TECHNICIAN B. AT 14:29:22, TECHNICIAN A SAID "HEY [TECHNICIAN B], CHECK OUT THIS COOL TRICK I LEARNED" WHILE TAKING OUT THE JUGGLING PINS. TECHNICIAN B TURNED TO LOOK JUST AS, AT 14:29:26, TECHNICIAN C ENTERED HOLDING THE CAKE.		

YOU KNOW THINGS ARE ABOUT TO GET BAD WHEN THE INCIDENT REPORT STARTS INCLUDING SECONDS IN THE TIMESTAMPS.

<https://xkcd.com/2553/>

Case Study: Maroochy Water Breach

(Ian Sommerville, https://www.youtube.com/watch?v=C_PRhTXp6VQ)

- Sewage system, SCADA* controlled system with 142 pumping stations over 1157 sq km installed in 1999
 - Special-purpose control computer at each station to control valves and alarms
 - Each system communicates with and is controlled by central control centre
 - Communications between pumping stations and control centre by radio, rather than wired network



Typical SCADA-controlled sewage system

*: Supervisory control and data acquisition

Case Study: Maroochy Water Breach

(Ian Sommerville, https://www.youtube.com/watch?v=C_PRhTXp6VQ)

- In 2000, the area sewage system had 47 unexpected faults causing extensive sewage spillage
- More than 1 million litres of untreated sewage released into waterways and local parks



Case Study: Maroochy Water Breach

(Ian Sommerville, https://www.youtube.com/watch?v=C_PRhTXp6VQ)

- Technical problems:
 - Pumps not operating when they should have been
 - Alarms failed to report problems to control centre
 - Communication difficulties between control centre and pumping stations
- Initially, the incidents were thought to have been caused by bugs in the new system
- Clue #1: Analysis of communications showed that problems were caused by specific station ID
 - System was reconfigured so that ID was not used
- Clue #2: ID was still appearing!
 - Its messages had to be malicious

Case Study: Maroochy Water Breach

(Ian Sommerville, https://www.youtube.com/watch?v=C_PRhTXp6VQ)

- Insider attack:
 - Vitek Boden worked for the system supplier that installed Maroochy system
 - Left the company and tried to get a job at Maroochy city council
 - Decided to take revenge
- Boden fell under suspicion and was put under surveillance
 - car was stopped after attack: equipment found
- A disgruntled employee:
 - Installed config program on own laptop
 - Stole radio equipment and control computer to impersonate genuine machine at pump installation
 - Used insecure radio links to re-configure pumping stations

Case Study: Maroochy Water Breach

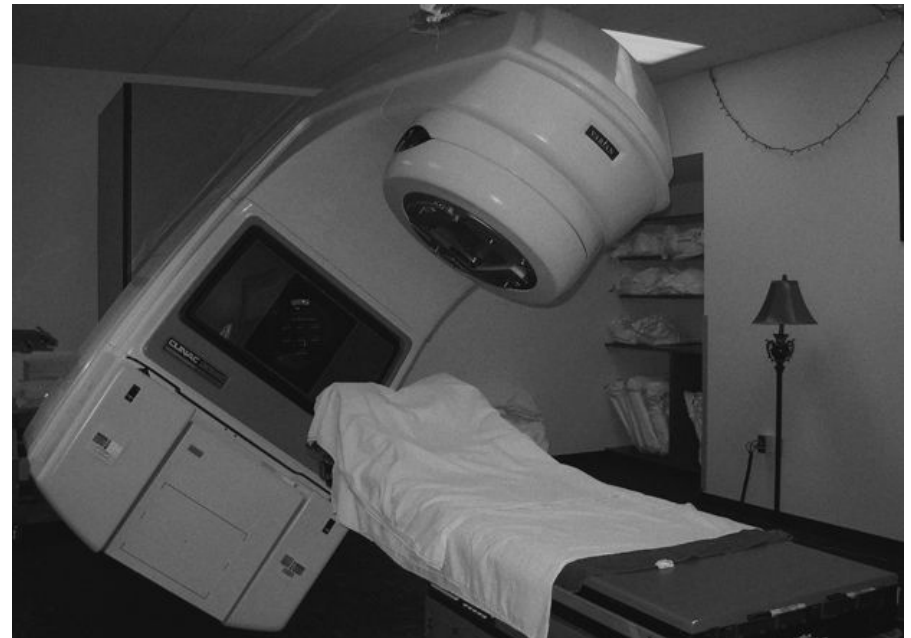
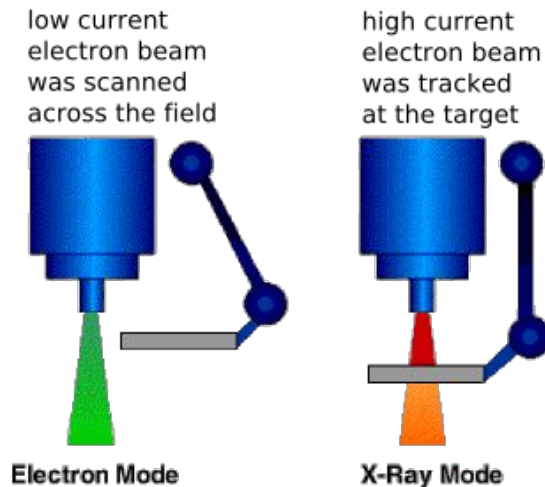
(Ian Sommerville, https://www.youtube.com/watch?v=C_PRhTXp6VQ)

The Maroochy Water Breach case study is often cited as an early wake-up call for the critical infrastructure sector, highlighting the need for improved cybersecurity practices to protect essential services, especially in wireless sensor networks, from cyber threats.

Case Study: The Therac-25

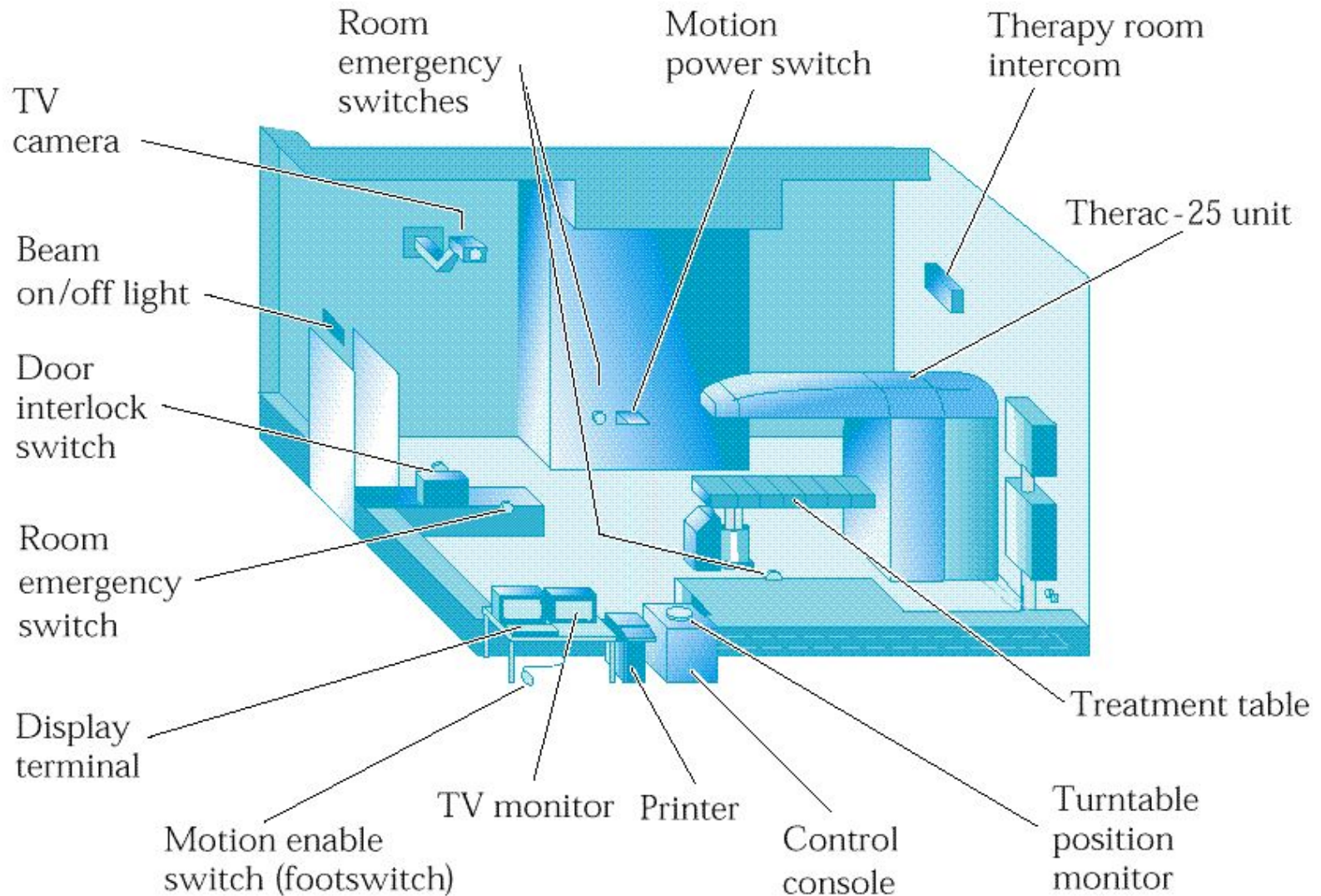
<https://www.youtube.com/watch?v=H4Xa45RGBQ8>

- Built in 1975, by Atomic Energy of Canada Ltd (AECL)
- Linear accelerator to kill tumors and cancerous cells
- Two modes:
 - Concentrated electron beams for surface, or:
 - X-ray photons using a filter to reach deeper tissues
- Less space required, less expensive



Case Study: The Therac-25

<https://www.youtube.com/watch?v=H4Xa45RGBQ8>

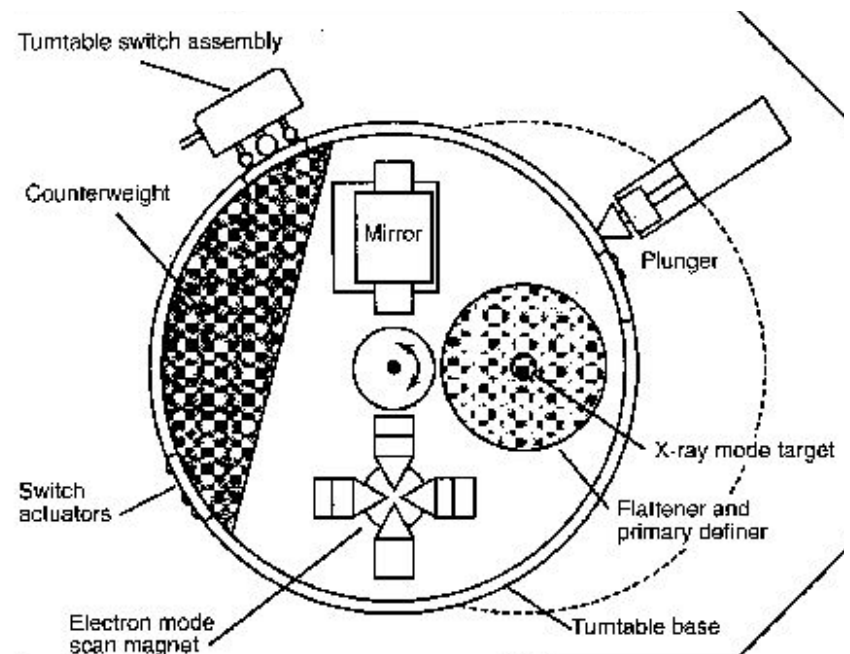


Case Study: The Therac-25

<https://www.youtube.com/watch?v=H4Xa45RGBQ8>

In electron therapy, the computer controls the beam energy (from 5 to 25 MeV) and current while scanning magnets spread the beam to a safe, therapeutic concentration.

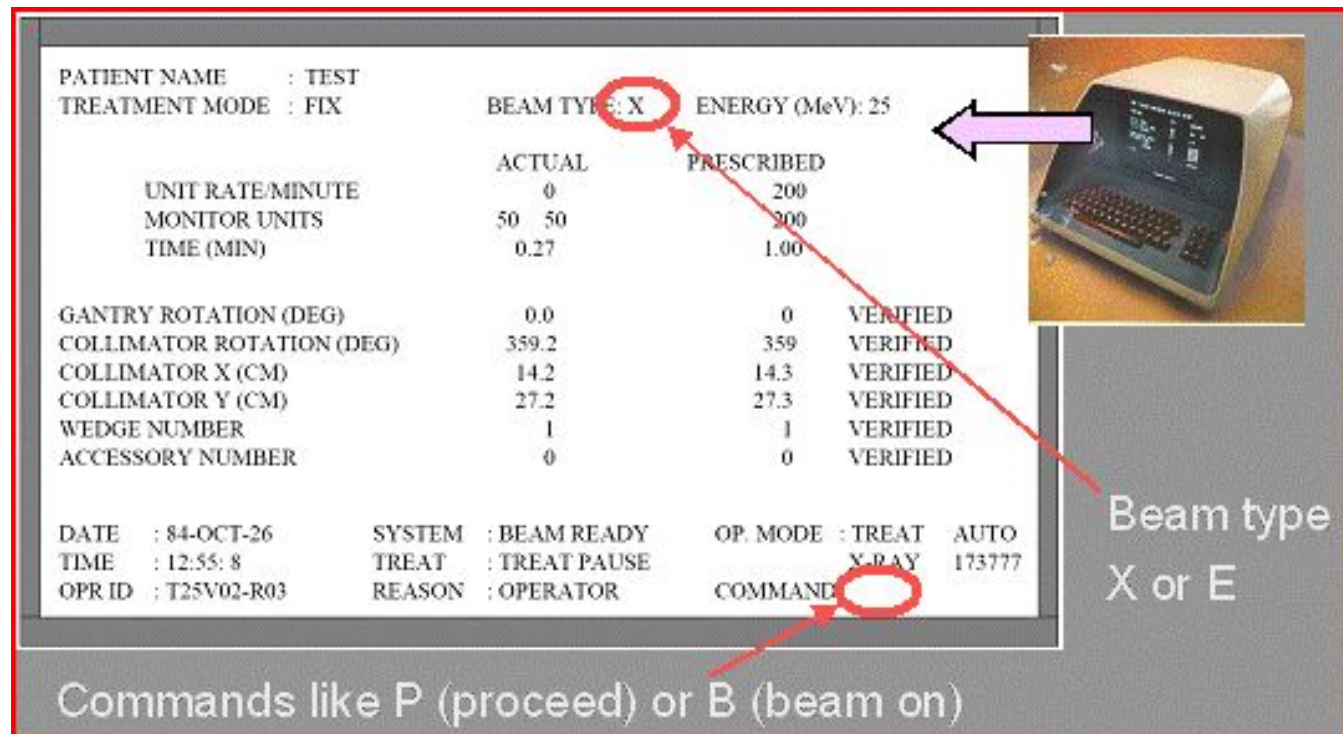
For X-ray therapy, 25 MeV is used. Much greater electron-beam current is required for photon mode (100 times greater than that for electron therapy)



Case Study: The Therac-25

<https://www.youtube.com/watch?v=H4Xa45RGBQ8>

- The operator's commands are mediated by software alone: in the Therac-25, software checks were substituted for many traditional hardware interlocks
- “easy” User interface through keyboard:



PATIENT NAME : TEST
TREATMENT MODE : FIX

BEAM TYPE : X ENERGY (MeV): 25

	ACTUAL	PRESCRIBED	
UNIT RATE/MINUTE	0	200	
MONITOR UNITS	50 50	200	
TIME (MIN)	0.27	1.00	
GANTRY ROTATION (DEG)	0.0	0	VERIFIED
COLLIMATOR ROTATION (DEG)	359.2	359	VERIFIED
COLLIMATOR X (CM)	14.2	14.3	VERIFIED
COLLIMATOR Y (CM)	27.2	27.3	VERIFIED
WEDGE NUMBER	1	1	VERIFIED
ACCESSORY NUMBER	0	0	VERIFIED

DATE : 84-OCT-26 SYSTEM : BEAM READY OP. MODE : TREAT AUTO
TIME : 12:55: 8 TREAT : TREAT PAUSE X-RAY 173777
OPR ID : T25V02-R03 REASON : OPERATOR COMMAND

Beam type
X or E

Commands like P (proceed) or B (beam on)

Case Study: The Therac-25

<https://www.youtube.com/watch?v=H4Xa45RGBQ8>

Overconfidence / negligence on both sides:

- Users (hospitals):
 - Successful operation on 100s of patients per year
 - High faith in manufacturer:
 - “additional hardware and software safety devices”*
 - “improvement of at least five orders of magnitude”*
 - Regularly: minor errors / warnings popping up
- AECL:
 - Software: no testing of modules
 - Under certain conditions: variable overflow
 - Hardware: completely controlled by software
 - No hardware safety interlocks

Case Study: The Therac-25

<https://www.youtube.com/watch?v=H4Xa45RGBQ8>

The Tylor, TX case:

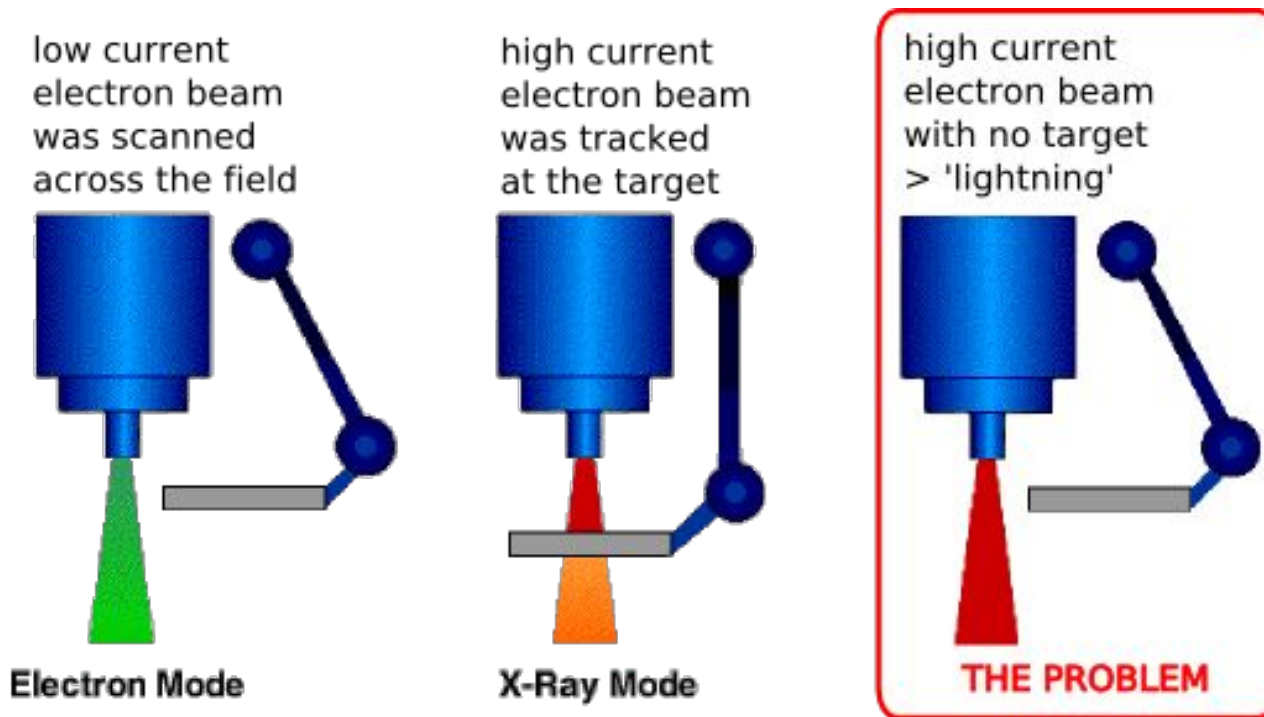
March 21, 1986: male patient came for his 9th treatment on the Therac-25, as follow-up to the removal of a tumor.

- Treatment: a 22-MeV electron-beam treatment of 180 rads over a 10 x 17-cm field on the upper back
- Operator:
 - Followed procedures, placed patient on table, left room
 - Entered data, first entered 'x', then corrected to 'e'
 - Verified all data was correct, then entered 'B' (beam on)
 - Errors: "Malfunction 54", "treatment pause",
only 6 (of 202) units delivered
 - Operator hits 'P' (proceed), then hears banging from the door
 - Video display was unplugged, audio monitor broken...

Case Study: The Therac-25

<https://www.youtube.com/watch?v=H4Xa45RGBQ8>

16,500 to 25,000 rads in less than 1 second over an area of about 1 cm were given...



tray including the target, a flattening filter, the collimator jaws and an ion chamber was moved OUT for "electron" mode, and IN for "photon" mode.

Case Study: The Therac-25

<https://www.youtube.com/watch?v=H4Xa45RGBQ8>

- patient died from complications of the overdose five months after the accident
- therac-25 was shut down for testing the day after this accident, but nobody could reproduce error
- center put machine back into service on April 7, 1986, convinced that it was performing properly!
- after 5 more cases, the FDA declared the Therac-25 to be defective
- AECL then produced an update with 20 changes (software and hardware), therac-25 is still in use today

Detailed analysis:

<http://ieeexplore.ieee.org/stamp/stamp.jsp?arnumber=274940>

Case Study: The Therac-25

<https://www.youtube.com/watch?v=H4Xa45RGBQ8>

The Therac-25 case study is a famous example in the study of software safety and engineering ethics, illustrating the potentially catastrophic consequences of software failure in safety-critical systems

Case Study: The Flououracil Incident

<http://www.gresham.ac.uk/lectures-and-events/designing-it-to-make-healthcare-safer>



- In July 2006, a patient was being treated according to a protocol that included high-dose fluorouracil and cisplatin:

5-Fluorouracil 5250 mg (at 4000 mg/m²) intravenous once continuous over 4 days... Continuous infusion via ambulatory infusion pump (Baseline regimen dose = 1000 mg/m²/day = 4000 mg/m²/4 days).

Case Study: The Flououracil Incident

<http://www.gresham.ac.uk/lectures-and-events/designing-it-to-make-healthcare-safer>



- patient instead received 5,250 mg of fluorouracil (4,000 mg/m²) over 4 hours instead of 4 days
- **Pump design** was causative factor
 - Same button for decimal point and up arrow
 - mL really is mL / hour
 - Help only given for option 1
 - ...

Case Study: The Flououracil Incident

<http://www.gresham.ac.uk/lectures-and-events/designing-it-to-make-healthcare-safer>



Human Factors Study:

2 hours

6 nurses

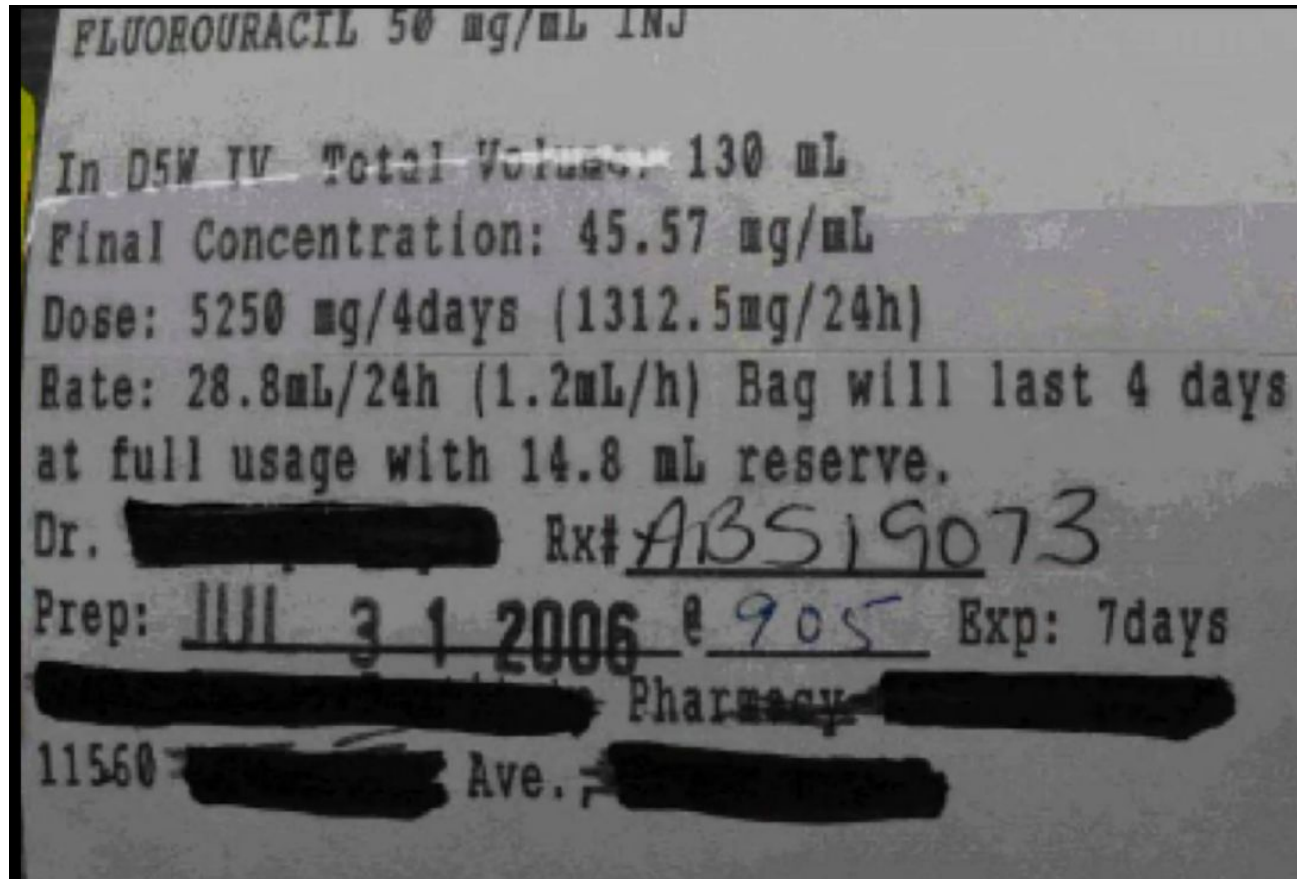
- 100% confused by setup or selection of mL/hr
- 100% pressed Start incorrectly
- 40% confused by user interface
- 60% needed hints to use it
- 60% confused by decimal point

60% entered incorrect data

Case Study: The Fluorouracil Incident

<http://www.gresham.ac.uk/lectures-and-events/designing-it-to-make-healthcare-safer>

Drug bag design:

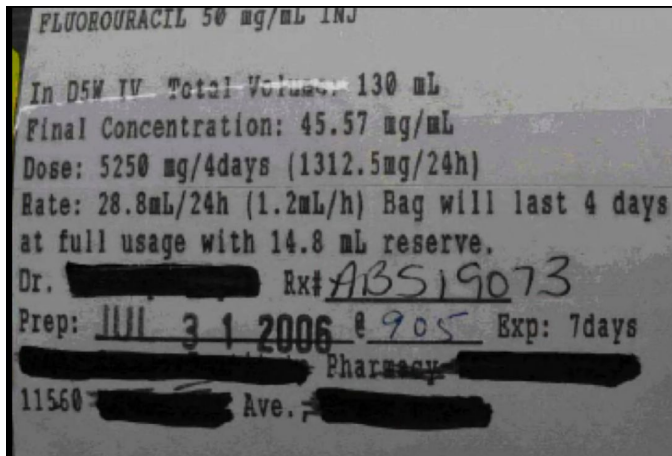


Case Study: The Flououracil Incident

<http://www.gresham.ac.uk/lectures-and-events/designing-it-to-make-healthcare-safer>

- *5-Fluorouracil 5250 mg (at 4000 mg/m²) intravenous once continuous over 4 days... Continuous infusion via ambulatory infusion pump (Baseline regimen dose = 1000 mg/m²/day = 4000 mg/m²/4 days).*

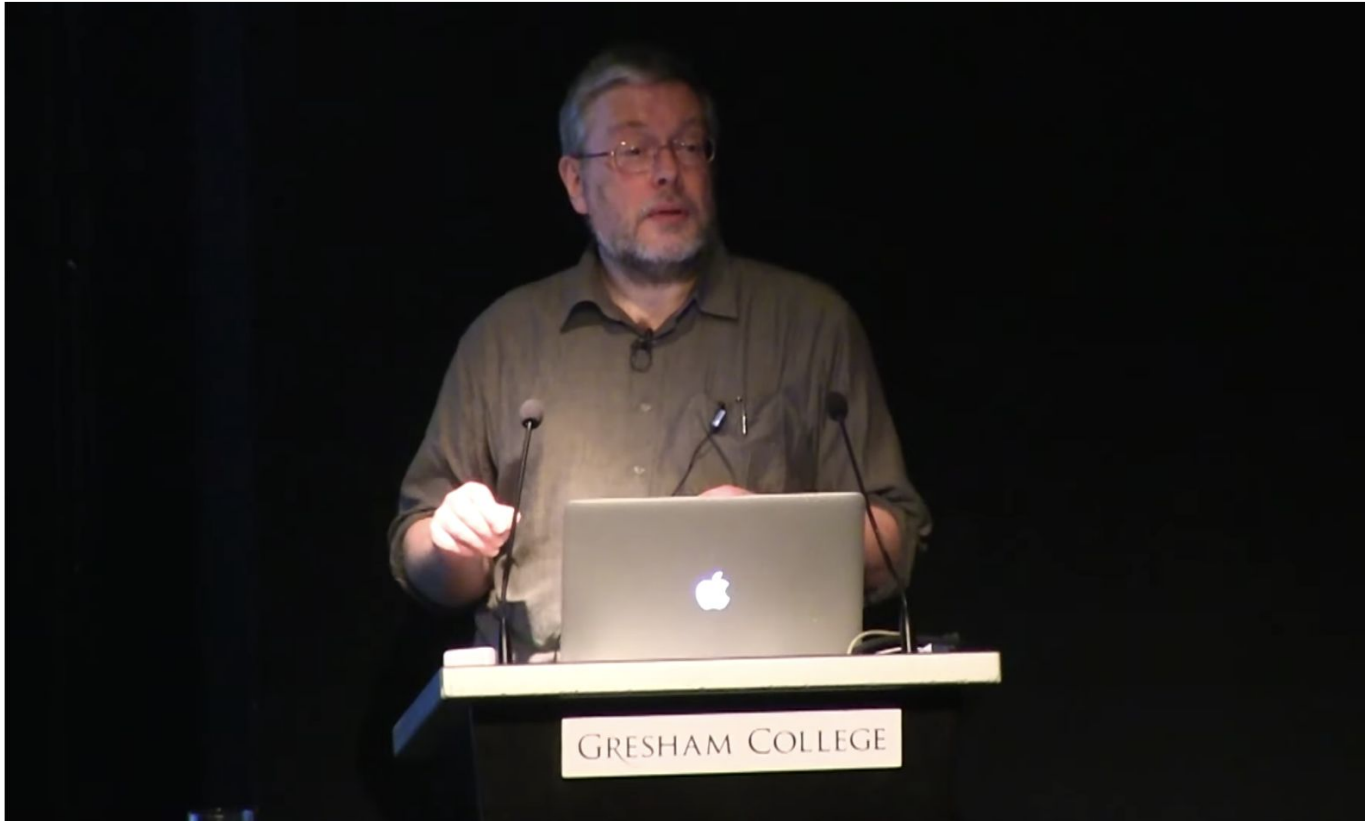
Drug bag:



Numbers printed	Numbers required
5,250 mg 4,000 mg/ m ² 4 days 1000 mg/ m ² /day 4000 mg/m ² /4 days 50 mg/mL 5924.48 mg 118.49 m 130 mL 45.57 mg/mL 5250 mg/4days 1312.5mg/24h 28.8mL/24h 1.2mL/h 4 days 14.8 mL reserve 905 Exp: 7days 11560	5250 mg 45.57 mg/mL 4 days

Case Study: The Flououracil Incident

<http://www.gresham.ac.uk/lectures-and-events/designing-it-to-make-healthcare-safer>

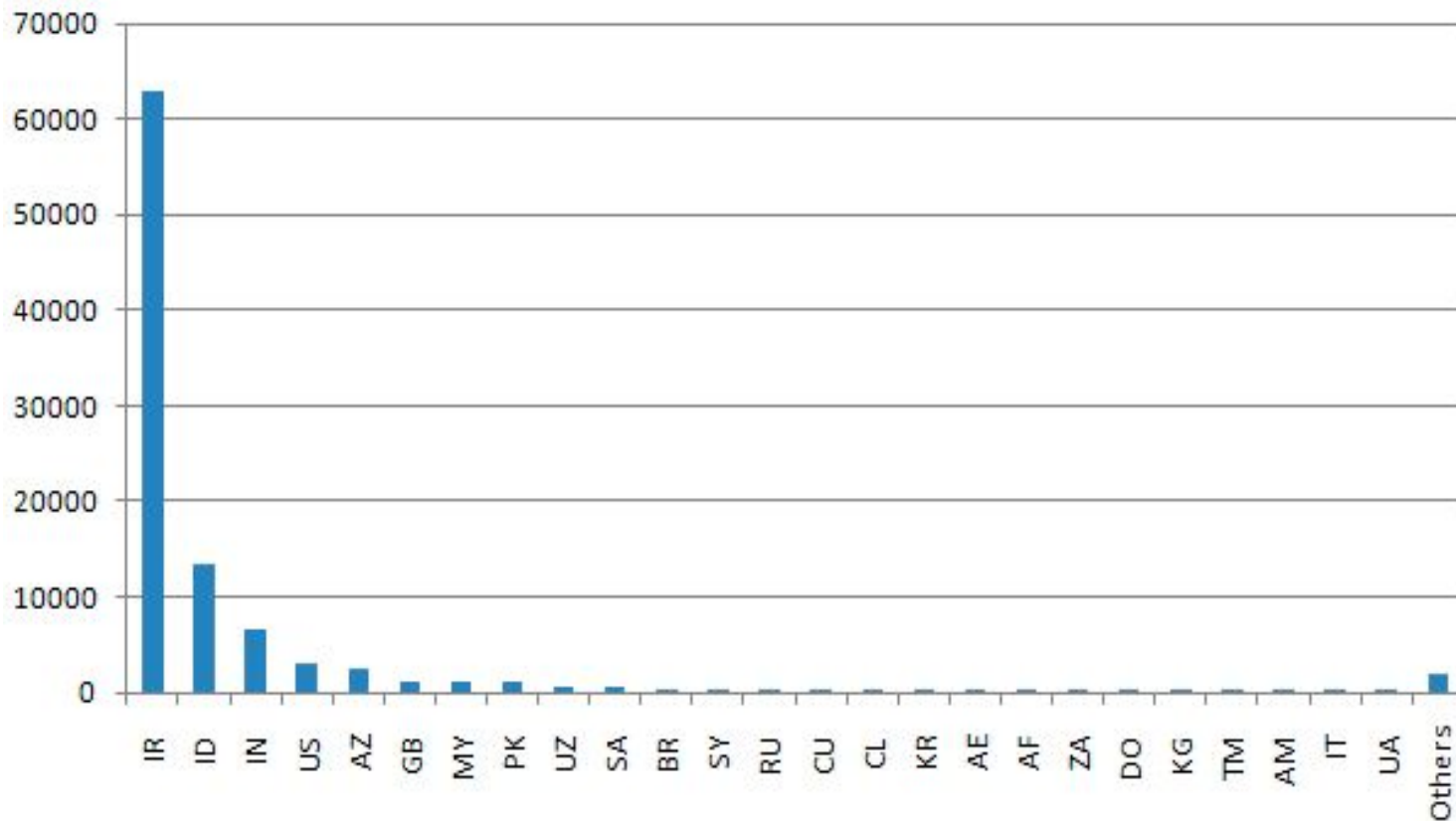


- *More information:*
Professor Harold Thimbleby, Designing IT to make Healthcare Safer:
<http://www.gresham.ac.uk/lectures-and-events/designing-it-to-make-healthcare-safer>

Case Study: Stuxnet

- computer worm: standalone malware program that can replicate itself to spread to other computers
- first variant of the worm appeared in June 2009, already deployed as early as 2005
- June 2010: security company VirusBlokAda discovers new worm
- Symantec later calls it W32.Stuxnet
- Virus infects MS Windows XP and Vista+
At MS: <https://www.youtube.com/watch?v=73HlkCI-GwA>
- Then targets specifically a Siemens system:
 - only high speed variable-frequency programmable logic motor controllers (PLC) from two vendors: Vacon (FIN) and Fararo Paya (IR)
 - only when the controllers are running at 807Hz to 1210Hz

Case Study: Stuxnet



Infected hosts - September 2010, Symantec

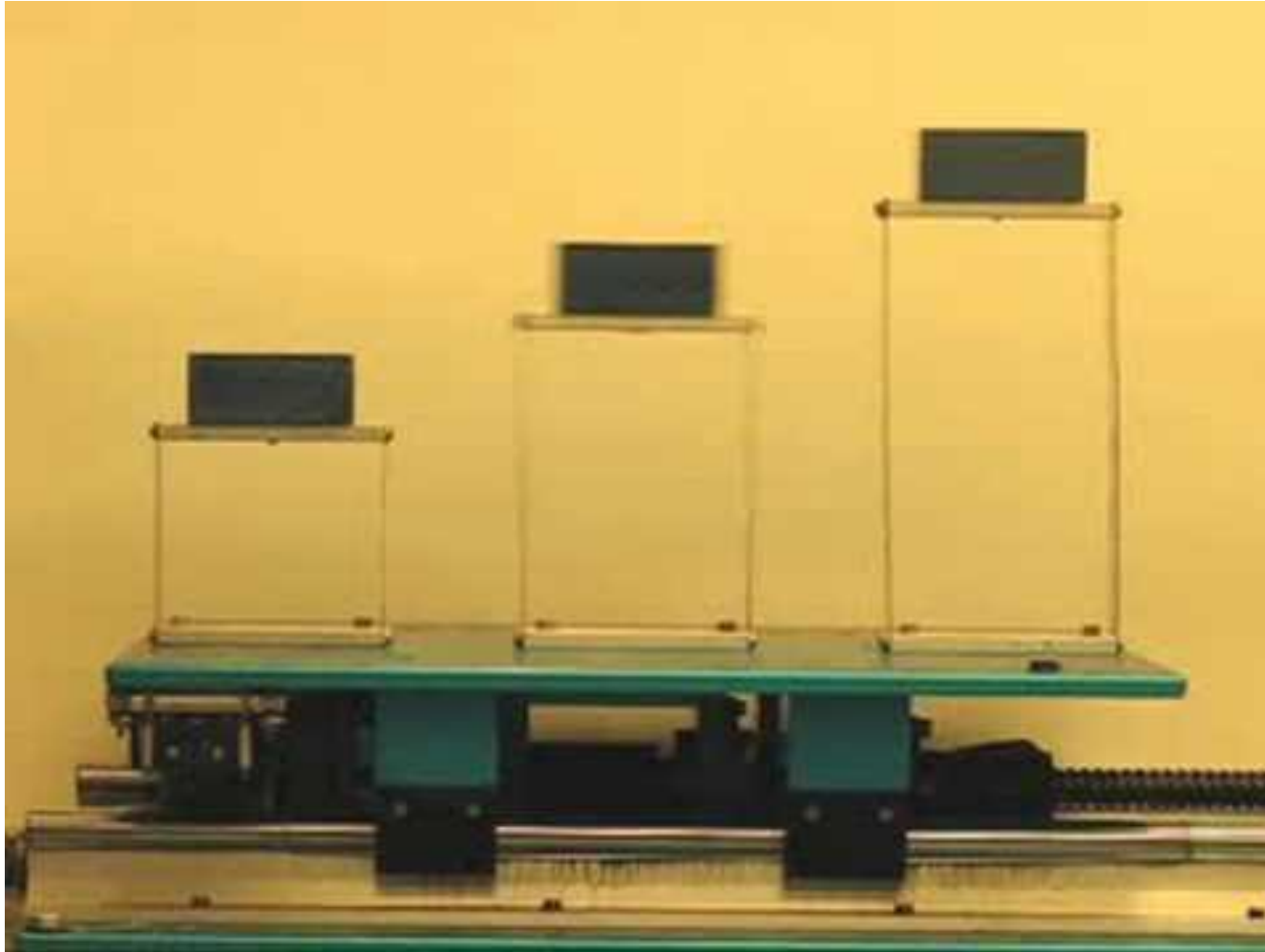
Case Study: Stuxnet



Siemens SIMATIC PLCs

- Lots of Industrial Control Systems operate by special assembly code on PLCs
- PLCs usually programmed from MS Windows
- Not connected via Internet (“airgap”)

Case Study: Stuxnet



Video: http://www.youtube.com/watch?v=LV_UuzEznHs

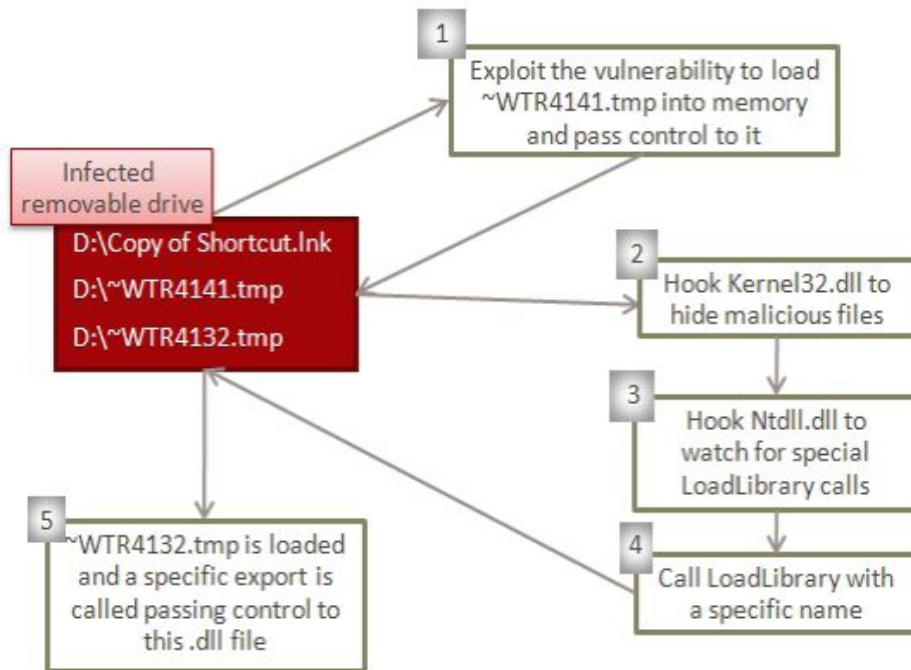
Case Study: Stuxnet



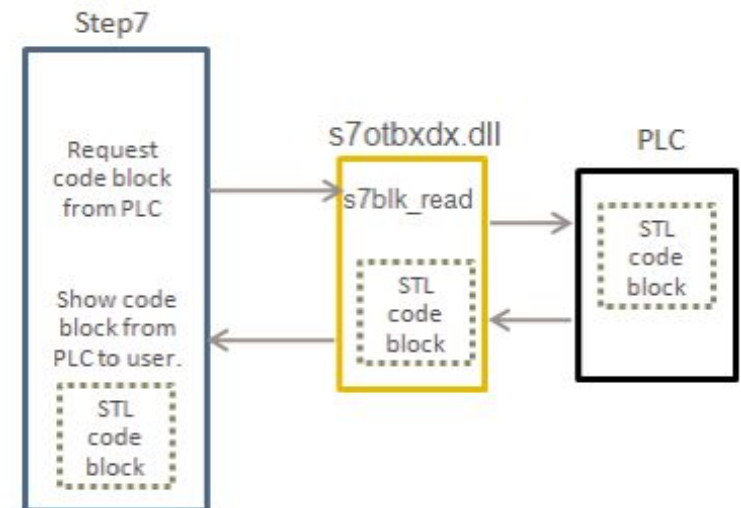
<https://www.youtube.com/watch?v=fJyWngDco3g>

Case Study: Stuxnet

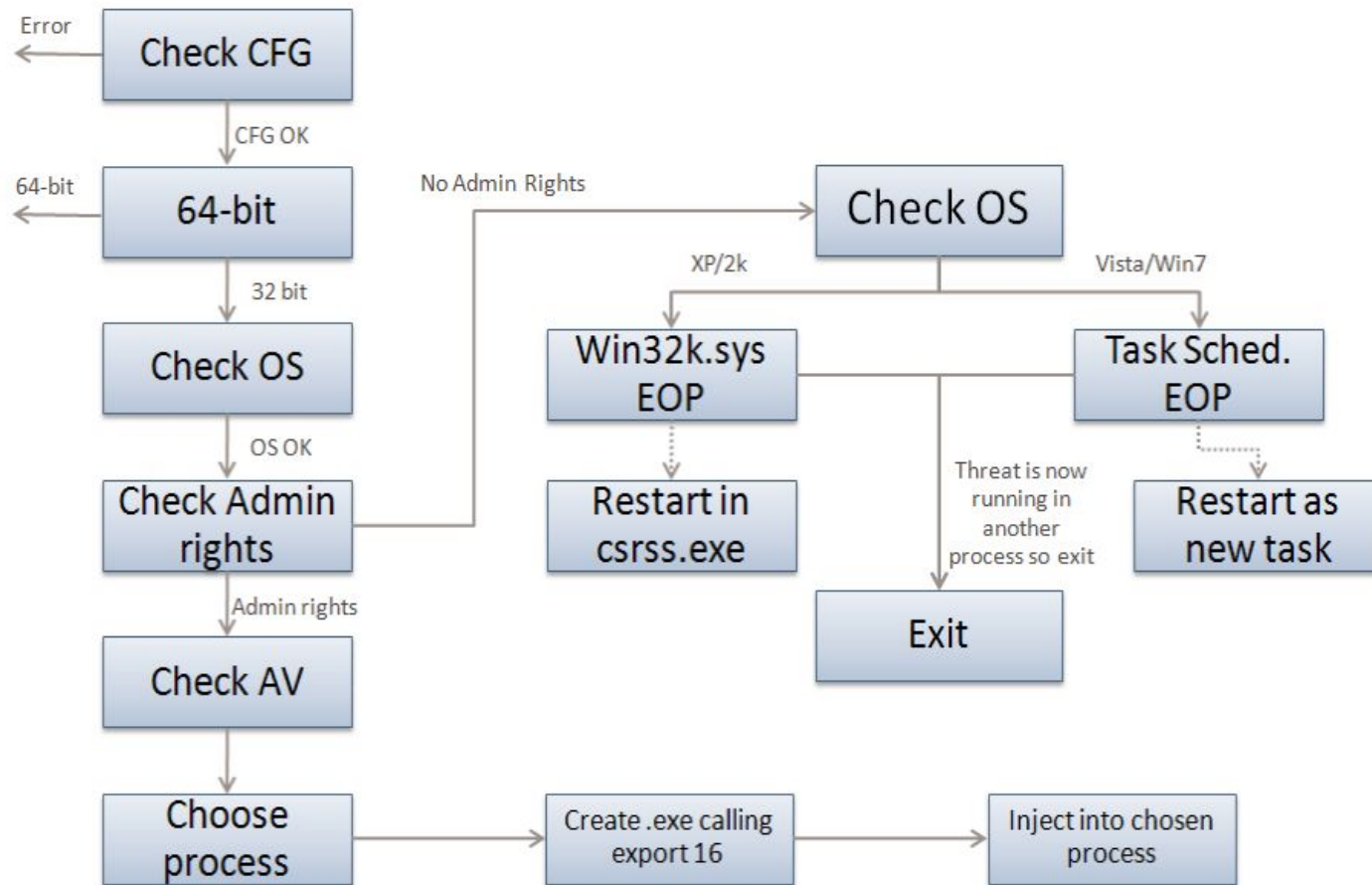
Propagation: USB sticks



Aim: reprogramming and masking output from PLCs



Case Study: Stuxnet



Case Study: Stuxnet

- Stuxnet tests if it can connect to
 - www.windowsupdate.com
 - www.msn.com
 - On port 80
- Contacts the command and control server
 - www.mypremierfutbol.com
 - www.todaysfutbol.com
 - The two URLs above previously pointed to servers in Malaysia and Denmark
 - Sends info about the compromised computer

Case Study: Stuxnet

- Stuxnet is a significant milestone in malicious code history for SCADA systems
 - It is the first to exploit multiple (4!) 0-day vulnerabilities
 - Used two (compromised) digital certificates
 - Injected code into industrial control systems
 - Hid the code from the operator
- Stuxnet is of great complexity
 - Requiring significant resources to develop

Case Study: Stuxnet

Stuxnet is one of the most well-known and studied examples of cyber warfare, illustrating the evolving nature of modern conflict and the growing importance of cybersecurity in protecting national security interests